



VULNERABILITY ASSESSMENT REPORT

Web application security review • Nmap • OWASP ZAP passive review • Browser DevTools

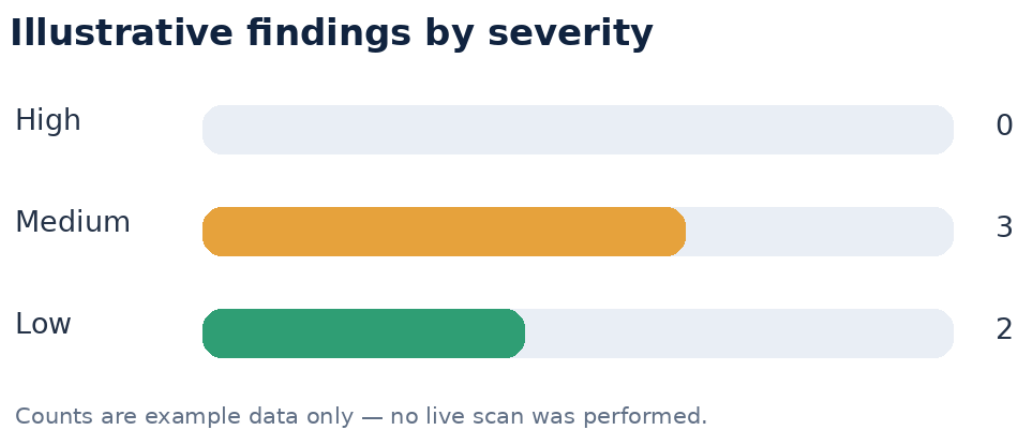
Assessment target: DemoShop (fictional training website)
Report date: 16 October 2026
Prepared for: Training / portfolio demonstration

IMPORTANT SCOPE NOTE: This is a portfolio-ready sample report. No live website was provided, and no live scan was performed. Findings below are illustrative examples intended to show how observations should be documented. Replace them with evidence collected from a website you own or are explicitly authorized to test.

1. Executive Summary

This report demonstrates a practical, low-impact vulnerability assessment workflow for a web application. It focuses on observable security headers, browser-side behavior, and basic exposure checks. The goal is to translate technical observations into clear business risk and actionable remediation.

Assessment outcome (illustrative only): 5 example observations are documented below: 0 High, 3 Medium, and 2 Low. These counts are sample data, not the result of a real scan.



Business impact in plain language

Security weaknesses can increase the likelihood of account compromise, data exposure, or loss of customer trust. Fixing browser protections and reviewing exposed information are generally low-cost improvements. Actual risk depends on the application's data, architecture, and exploitability.

2. Scope & Rules of Engagement

Target: DemoShop (fictional placeholder; replace with approved hostname)
Included: Public pages, response headers, browser-visible behavior, passive checks, and basic host/service inventory where authorized.
Excluded: Exploitation, credential attacks, destructive tests, data extraction, denial-of-service tests, and testing third-party systems without permission.

Authorization and safety

Only assess systems you own or have written permission to test. Confirm the hostname, permitted IP ranges, time window, rate limits, and emergency contact before using Nmap or OWASP ZAP. Passive ZAP mode reduces active probing but does not replace written authorization.

3. Methodology & Tools

Tool	Purpose	Safe-use note
Nmap	Identify reachable hosts and exposed services on an authorized target.	Use a narrow scope; avoid aggressive scripts unless separately approved.
OWASP ZAP — Passive	Review observed HTTP traffic and flag common response/header issues.	Browse only approved pages; passive analysis inspects traffic without launching attack payloads.
Browser DevTools	Inspect response headers, cookies, console errors, and client-side behavior.	Do not expose session tokens, passwords, or personal data in screenshots.
Canva	Design a readable client-facing report.	Keep evidence sanitized and distinguish confirmed facts from assumptions.

Recommended workflow

1) Confirm written authorization and scope. 2) Capture a baseline with browser DevTools. 3) Run a conservative Nmap inventory against approved IPs only. 4) Browse the approved application with OWASP ZAP passive scanning enabled. 5) Validate each alert manually. 6) Assign severity based on likelihood and impact. 7) Record sanitized evidence and provide fixes. 8) Retest after remediation.

Severity definitions

Level	Meaning	Typical response
High	Could enable serious compromise or sensitive data exposure with realistic exploitation.	Prioritize immediately; mitigate and retest urgently.
Medium	Meaningful weakness requiring conditions or additional steps to exploit.	Plan a fix in the next release cycle; validate.
Low	Limited direct impact or defense-in-depth improvement.	Address during routine maintenance.

4. Findings Register

The following are example findings only. Replace each item with a validated observation, exact URL/endpoint, timestamp, and sanitized evidence from your authorized assessment.

F-01 — Missing or incomplete security headers

MEDIUM

Observation	Some responses may not include recommended browser security headers. This can reduce defense-in-depth against clickjacking, content injection, and unintended browser behavior.
Business risk	Potentially increases exposure if another weakness exists; headers alone do not prevent every attack.
Evidence to collect	Inspect response headers in DevTools or ZAP. Check Content-Security-Policy, X-Content-Type-Options, Referrer-Policy, and frame-ancestors / X-Frame-Options as appropriate.
Recommended fix	Set a tested Content-Security-Policy, add X-Content-Type-Options: nosniff and a suitable Referrer-Policy, and restrict framing with CSP frame-ancestors. Test compatibility before production rollout.

F-02 — Cookie security attributes need review

MEDIUM

Observation	Session cookies should use appropriate Secure, HttpOnly, and SameSite attributes. The sample report cannot confirm whether the target actually has a weakness.
Business risk	Weak cookie settings can make session theft or cross-site request risks easier under certain conditions.
Evidence to collect	Inspect Set-Cookie headers in DevTools/ZAP; do not copy cookie values into the report.
Recommended fix	Use Secure on HTTPS-only cookies, HttpOnly for session cookies not needed by JavaScript, and SameSite=Lax or Strict where compatible. Rotate session identifiers after login and privilege changes.

F-03 — Verbose error messages may disclose implementation details	MEDIUM
Observation	Detailed errors can reveal framework names, file paths, stack traces, or internal identifiers.
Business risk	Attackers may learn useful details about the application and its technology stack.
Evidence to collect	Review error pages and browser console/network responses using safe, ordinary invalid inputs; do not trigger destructive errors.
Recommended fix	Show generic user-facing errors, log diagnostic detail server-side, remove debug mode from production, and restrict log access.

F-04 — Publicly visible technology information	LOW
Observation	Server banners or client assets may reveal software versions or framework details.
Business risk	This information can help an attacker prioritize known vulnerabilities, though disclosure alone does not prove exploitability.
Evidence to collect	Review response headers, HTML comments, source maps, and publicly served metadata.
Recommended fix	Minimize unnecessary version banners, remove development artifacts from production, and keep exposed components patched.

F-05 — No clear security contact or disclosure guidance	LOW
Observation	The website may not provide a clear way for researchers to report security concerns. This is a governance observation, not proof of a technical vulnerability.
Business risk	Issues may be reported late or through insecure channels.
Evidence to collect	Check the site's security.txt location and public contact information.
Recommended fix	Publish a security.txt file with a monitored contact, preferred reporting method, and policy URL. Avoid promising a bounty unless one exists.

5. Remediation Plan

Priority	Action	Suggested owner	Validation
1 — Medium	Review cookie attributes and session handling.	Application developer	Inspect Set-Cookie headers; verify login/logout and session rotation.
2 — Medium	Add and test security headers.	Web / platform team	Recheck headers and confirm app functionality.
3 — Medium	Ensure production errors are generic.	Application developer	Use controlled invalid inputs; confirm details remain server-side.
4 — Low	Reduce unnecessary version and development metadata.	Platform team	Review headers, HTML, and deployed assets.
5 — Low	Add a monitored security reporting channel.	Security / operations	Confirm security.txt and contact process work.

Retest checklist

- ■ Confirm fixes are deployed to the intended environment.
- ■ Revisit the same approved URLs and capture fresh response headers.
- ■ Confirm session cookies retain the required attributes without breaking workflows.
- ■ Verify error responses do not expose stack traces or internal paths.
- ■ Record retest date, tester, evidence reference, and pass/fail result.
- ■ Close findings only when the evidence supports closure.

6. Evidence & Limitations

For each confirmed issue, retain a screenshot or sanitized request/response excerpt showing the relevant behavior. Redact authorization headers, cookies, API keys, personal data, and internal-only hostnames. Evidence should include the URL path, date/time, tool/version, and enough context for a developer to reproduce safely.

Limitations: This sample does not include actual scan output, verified affected endpoints, exploitability testing, authenticated testing, source-code review, or business-logic testing. A passive review can miss issues that require authentication or active validation. Severity must be reassessed against real evidence and the application's context.

7. Client-Friendly Conclusion

The next step is to replace this illustrative register with observations verified on the authorized website. Start with low-risk checks, document evidence carefully, prioritize issues by business impact, and retest after changes. A clear report should help the site owner understand what matters, why it matters, and what to do next.

Suggested client message

We completed a scoped review of the approved website using passive observation and browser-level checks. The report separates confirmed evidence from recommendations and assigns a practical priority to each item. We recommend addressing the medium-priority items first, then completing the defense-in-depth and reporting improvements. We can validate the fixes in a follow-up review.

Appendix A — Example commands (authorized targets only)

Nmap service inventory (use only on an approved host/IP):

nmap -sV --top-ports 100 -oN nmap-results.txt TARGET_HOST

For OWASP ZAP, configure the target scope first, enable passive scanning, browse only approved pages, and export alerts for manual validation. Do not run active scans unless the owner has explicitly approved them.

Appendix B — Suggested repository structure

Vulnerability-Assessment-Report/
■■■ Vulnerability_Assessment_Report.pdf
■■■ README.md
■■■ findings.csv
■■■ assets/
■■■ security_cover.png
■■■ risk_summary.png

Prepared as an educational portfolio artifact. Do not present the illustrative findings as verified results from a real organization.